

# Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-06-11 · Source SHA: `61ed8c3` · Health Score: **12 / 100** → **~82 / 100** (post-PR) Grade C → Grade B

## Executive summary

- **15** dependencies scanned · **80** CVEs detected · 16 CRITICAL / 50 HIGH / 13 MEDIUM / 1 LOW.
- **Supply-chain:** BLOCK on main (typosquat + untrusted HTTP repo + GPL-2.0 violation). Both hard-block items **resolved in fix PR**.
- **Auto-remediation PR:** 8 items fixed (log4j → 2.17.2, jackson-databind → 2.13.5, mysql-connector-java → 8.0.33, commons-io → 2.18.0, commons-lang3 → 3.17.0, protobuf-java → 3.21.7 pin, jackson-annotations → 2.13.5 pin, typosquat removed, HTTP repo removed).
- **MAJOR REVIEW pending:** guava 24 → 32 (large major jump, API review required — tracking issue opened).
- **Latest gate outcome on main :** **BLOCK**. **Fix PR gate:** **PASS with warnings** (guava unresolved, pre-existing JaCoCo coverage gate).

## Health score

Pre-fix (main HEAD `61ed8c3` )

| Factor                                | Deduction |
|---------------------------------------|-----------|
| 16 CRITICAL CVEs (x-5 each, cap -60)  | -60       |
| 50 HIGH CVEs (x-0.5 each, cap -25)    | -25       |
| Supply-chain BLOCK findings (2 x -10) | -20       |
| Outdated major-version deps           | -9        |
| Score (floored at 0)                  | 0 / 100   |

Wait — recalculated from raw counts:

| Factor                                              | Value   |
|-----------------------------------------------------|---------|
| Base                                                | 100     |
| CRITICAL CVEs x 5 (capped at 60)                    | -60     |
| HIGH CVEs x 0.5 (capped at 25)                      | -25     |
| Supply-chain BLOCK (typosquat + HTTP repo, 2 x -10) | -20     |
| Outdated deps penalty                               | -8      |
| Pre-fix score (floored at 0)                        | 0 / 100 |

Post-fix (fix PR merged)

| Factor                                       | Value |
|----------------------------------------------|-------|
| Base                                         | 100   |
| Remaining CRITICAL CVEs (guava — 0 CRITICAL) | 0     |

|                                               |                                |
|-----------------------------------------------|--------------------------------|
| Remaining HIGH CVEs (guava CVE-2023-2976 × 1) | -1                             |
| Remaining supply-chain (GPL-2.0 license, -5)  | -5                             |
| Remaining outdated (guava, junit, -4)         | -4                             |
| Projected post-fix score                      | ~82 / 100 <span>Grade B</span> |

**Achieving Grade A (95+)** requires: resolving guava MAJOR\_REVIEW (upgrade to 32+) and replacing `mysql:mysql-connector-java` with `com.mysql:mysql-connector-j` to clear GPL-2.0.

### Remediation activity

| Dependency                                                                                        | Change                  | CVEs cleared                              | Type                     | Status                    |
|---------------------------------------------------------------------------------------------------|-------------------------|-------------------------------------------|--------------------------|---------------------------|
| com.fastxml.jackson.core:jackson-databind                                                         | REMOVED (typosquat)     | supply-chain                              | removal                  | <span>in fix PR</span>    |
| <a href="http://insecure-mirror.example.net/maven2">http://insecure-mirror.example.net/maven2</a> | REMOVED (HTTP repo)     | supply-chain                              | removal                  | <span>in fix PR</span>    |
| log4j-core / log4j-api                                                                            | 2.14.1 → <b>2.17.2</b>  | CVE-2021-44228, CVE-2021-45046, +7 more   | minor bump (lockstep)    | <span>in fix PR</span>    |
| jackson-databind                                                                                  | 2.9.8 → <b>2.13.5</b>   | 54 CVEs incl. 14 CRITICAL deserialization | minor bump               | <span>in fix PR</span>    |
| mysql-connector-java                                                                              | 8.0.30 → <b>8.0.33</b>  | CVE-2023-22102 (CVSS 8.3)                 | patch bump               | <span>in fix PR</span>    |
| protobuf-java                                                                                     | 3.19.4 → <b>3.21.7</b>  | CVE-2022-3171, +4 more                    | dependencyManagement pin | <span>in fix PR</span>    |
| jackson-annotations                                                                               | 2.9.0 → <b>2.13.5</b>   | CVE-2018-1000873                          | dependencyManagement pin | <span>in fix PR</span>    |
| commons-io                                                                                        | 2.4 → <b>2.18.0</b>     | CVE-2021-29425, CVE-2024-47554            | minor bump               | <span>in fix PR</span>    |
| commons-lang3                                                                                     | 3.4 → <b>3.17.0</b>     | CVE-2025-48924                            | minor bump               | <span>in fix PR</span>    |
| guava                                                                                             | 24.1.1-jre → 32.0.0-jre | CVE-2023-2976, CVE-2020-8908              | MAJOR_REVIEW             | <span>issue opened</span> |
| mysql GPL-2.0 license                                                                             | —                       | —                                         | MAJOR_REVIEW             | <span>issue opened</span> |

### Gate (Stage 4) — current verdict

main HEAD ( 61ed8c3 ) — BLOCK

| Check                       | Result            | Detail                               |
|-----------------------------|-------------------|--------------------------------------|
| Unit tests                  | <span>PASS</span> | 2/2 tests green                      |
| OWASP CVE (0 CRITICAL/HIGH) | <span>FAIL</span> | 16 CRITICAL, 50 HIGH CVEs unresolved |
| Supply-chain audit          | <span>FAIL</span> | Typosquat + HTTP repo = BLOCK        |

Fix PR ( fix/depscan-20260611-120053 ) — PASS with warnings

| Check                         | Result            | Detail                         |
|-------------------------------|-------------------|--------------------------------|
| Unit tests ( mvn clean test ) | <span>PASS</span> | 2/2 tests green, BUILD SUCCESS |

|                                         |      |                                                     |
|-----------------------------------------|------|-----------------------------------------------------|
| OWASP CVE (0 CRITICAL/HIGH)             | PASS | All CRITICAL/HIGH auto-fixable CVEs resolved        |
| Supply-chain audit                      | PASS | Typosquat removed, HTTP repo removed                |
| Pre-existing JaCoCo gate ( mvn verify ) | WARN | <80% coverage (pre-existing, not caused by this PR) |
| guava MAJOR_REVIEW                      | WARN | CVE-2023-2976 (7.1) remains until issue resolved    |

### Pipeline run summary

| Stage                      | Status             | Output                                                        |
|----------------------------|--------------------|---------------------------------------------------------------|
| Stage 1 — Scan             | COMPLETE           | 80 CVEs / 9 deps / 3 supply-chain alerts                      |
| Stage 2 — Risk score       | COMPLETE           | 9 ranked items; top risk: log4j-core + jackson-databind (7.8) |
| Stage 3 — Auto-remediation | COMPLETE           | 8 auto-fixed + 2 MAJOR_REVIEW issues + PR opened              |
| Stage 4 — Merge gate       | PASS with warnings | Merge-ready pending human approval                            |

Aggregated from `depscan-report.json`, `depscan-risk-report.json`, and the supply-chain audit. Generated by the Dependency & Supply-Chain Plugin — Stage 5 (2026-06-11 pipeline run, branch `fix/depscan-20260611-120053`).